

CS673 · ITERATION 1

SAFEDROP

Inventory Management & Checkout Service

Team 3 · Iteration 1 Review · September 2026

Alexa Stein

Team Lead

Amber Rastella

Security Lead

Alex Picard

Configuration Lead

Mateus Silva

Requirements Lead

Orelmis Toribio

QA Lead

github.com/BUMETCS673/CS673OLF26P3

Our Iteration 0 Promises, Scored

Alexa

Data model

*Multi-tenant schema,
indexed by organization*

DELIVERED

Seven collections. Every tenant-owned document carries orgId, and every tenant index leads with it.

Authentication

*Login, sessions,
role assignment*

DELIVERED

Self-managed bcrypt + JWT with rotating refresh tokens. Three roles, enforced server-side.

Core workflow

*Request, approve,
check out, return*

DELIVERED

Ten transitions behind one table. Each commits its audit entry in the same transaction.

Pipeline live

*Tests, CodeQL, and
staging deploys running*

STAGING ONLY

Six CI jobs green on every push; staging auto-deploys. Production promotion is still a placeholder.

One thing we promised and have not finished: audit immutability at the database layer. It is on slide 18.

Requirements: The Essential Set

Mateus

Portal creation & user UI	Organization bootstrap, member invite, role change, user management screen	SCRUM-100, 116-118, 121	DONE
Check out / return items	Submit, cancel, approve, deny, record handoff, record return	SCRUM-119, 120, 135, 136	DONE
Login & authentication	Sign in, sessions, forgotten password, forced password change	SCRUM-21, 22, 101	DONE
Audit log	Chain of custody per asset; audit log with actor, action, target and date filters	SCRUM-29, 46	IN REVIEW
Admin dashboard	Inventory counts, checkout activity, asset create / edit / retire	SCRUM-102, 122, 134	DONE

All five essential features have code merged. Not shipped: the two-step return with condition capture (SCRUM-57) — it moves to Iteration 2.

Our Estimate Was Wrong by 70%

Mateus

70 h

originally estimated
for Iteration 1

119 h

revised against the
kickoff breakdown

+70%

the size of the
underestimate

**Found by us, not
by the deadline**

Where the hours went

- The audit-log epic was estimated at 8 hours and broke down to roughly 32 — a single line item off by 24 hours.
- Scoping the frontend added roughly 25 hours that no feature estimate had accounted for at all.

What we changed

- Iteration 2 is sized against the revised figure, not the original.
- The original per-feature numbers stay in the SPPP as written, so the size of the error stays visible.
- Every story is broken to subtasks before it is estimated.

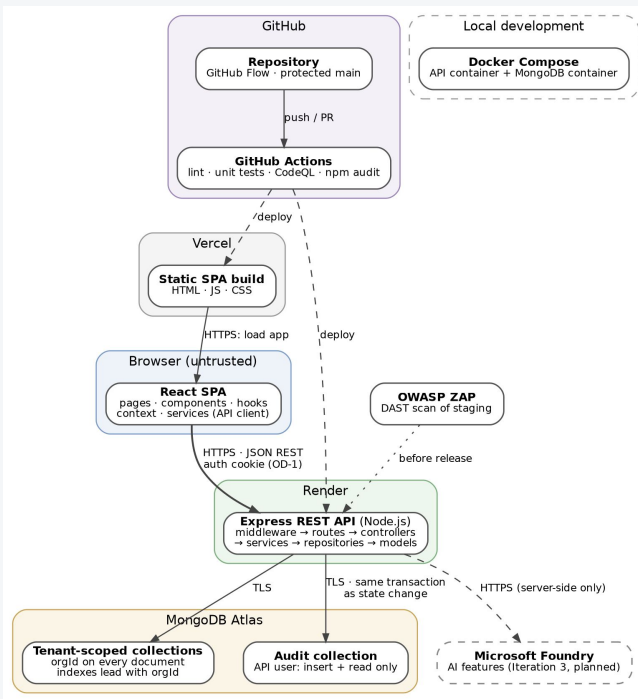
Recorded in SPPP v1.1 under SCRUM-131. The estimate was revised at the Iteration 1 kickoff, not reconstructed afterwards.

Architecture

Alex

Three tiers, one place to get security right

- A React SPA on Vercel, an Express API on Render, and MongoDB Atlas. The API is the only component with database access.
- The browser is treated as untrusted. Anything the SPA sends is validated and authorised by the API regardless of what the interface allows.
- OD-1 resolved: the SPA calls /api on its own origin and Vercel forwards to Render, so session cookies stay first-party and SameSite=Lax applies.

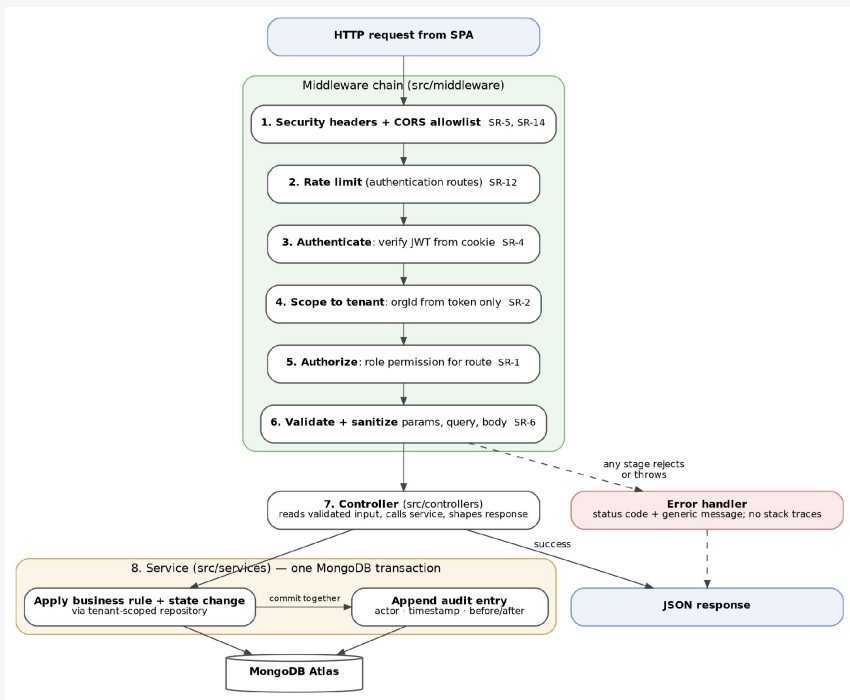


Every Request Takes the Same Path

Alex

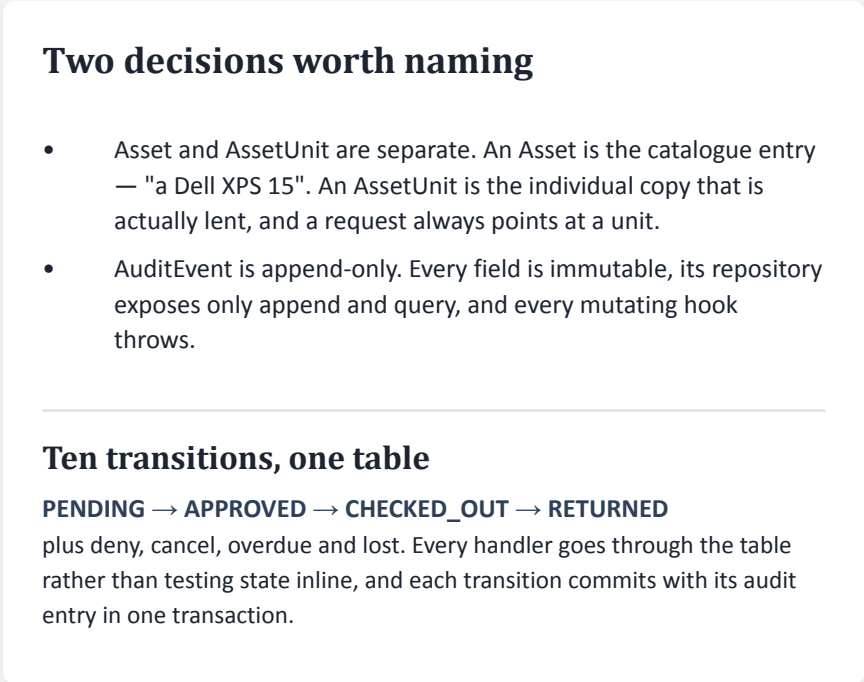
Security is structural, not sprinkled

- Tenant scoping and authorisation sit in the request path itself, so no individual route can skip them.
- Deny by default: every route must declare the permission it requires, and one that declares none is refused when the route table is built.
- Authentication runs before validation, so unauthenticated requests are rejected before the server parses attacker-controlled input.



SDD v0.2 §2.5, Figure 2. A test walks the built route table and checks all 29 routes against the permission matrix.

Amber



SDD v0.2 §3 and §7, Figure 3. Fields shown are those defined in the Mongoose schemas; the transition table is the authority every handler consults.

Design Decisions We Closed

Amber

OD-1

Cookies across domains

Vercel proxy — cookies are first-party,
SameSite=Lax

OD-2

Where the audit entry is written

Inside the service transaction, not trailing
middleware

OD-3

Account and membership model

Email unique per organization; admins invite, no
self-registration

OD-6

Library selections

Mongoose, Zod, Helmet, express-rate-limit

OD-2 changed the Iteration 0 design

Our Iteration 0 deck showed "write audit entry" as the last step of the middleware chain. As trailing middleware it would run after the state change had already committed, so a crash between the two would leave a change with no audit record. The write moved into the service transaction. Tests prove the rollback.

Still open

OD-4 permission matrix and OD-5 / OD-7 need team ratification. OD-8, ownership of the design sections, needs an owner.

SDD v0.2 §10.1. Open decisions are tracked by number so an unresolved choice stays visible rather than being settled silently.

What Iteration 1 Actually Ships

Mateus

16

screens

29

API routes

7

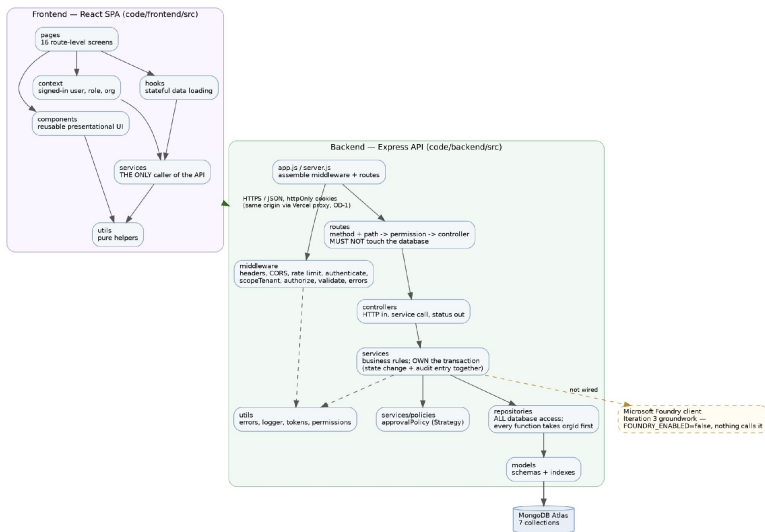
collections

3

roles

13

audit actions



Dependencies point one way

- In the backend a layer may use the layers beneath it and never above, so routes cannot reach the database and repositories cannot hold business rules.
- In the frontend only src/services calls the API — enforced by ESLint for components, pages, hooks and context.
- Any layer can be tested with the one beneath it mocked, and tenant scoping has exactly one place it can go wrong.

SDD v0.2 §3.2 and §4.2, Figure 4. The Foundry client is drawn detached because nothing calls it in Iteration 1.

Demo: Signing In

Orelmis

The organization is part of the credential

- Sign-in takes an organization slug alongside email and password, because email is unique per organization rather than across SafeDrop (OD-3).
- Passwords are hashed with bcrypt at cost 12, with a per-hash salt (SR-3).
- Every failure returns the same generic message. When no matching user exists the server still compares against a dummy hash, so response timing does not reveal which addresses have accounts.
- The route is rate-limited against brute force and credential stuffing (SR-12).

Sign in to SafeDrop

Organization

The short name of your organization, e.g. acme-robotics.

Email

Password

Sign in

[Forgot password?](#)

New here? [Create an organization](#)

Captured against the frontend test suite's fixture dataset, whose response shapes mirror the real API contracts.

Demo: Browsing and Requesting

Orelmis

SafeDrop [Catalog](#) [My requests](#) [Approvals](#) [Dashboard](#) [Users](#) [Audit log](#)

Ada Admin · Acme Robotics · Organization admin

[Sign out](#)

Catalog

[New asset](#)

Assets

Name	Category
Dell XPS 15	laptop
Canon EOS R6	camera

SafeDrop · CS673 Team 3 · Iteration 1

Every role sees the catalogue

It is the first screen after signing in. A member opens an asset, sees its units, and submits a request against one unit.

The navigation is the permission map

Approvals, Dashboard, Users and Audit log appear here because this user is an Org Admin. A member sees a shorter bar — and the API refuses the routes regardless.

Demo: The Approval Queue

Orelmis

SafeDrop [Catalog](#) [My requests](#) [Approvals](#) [Dashboard](#) [Users](#) [Audit log](#)

Ada Admin · Acme Robotics · Organization admin

[Sign out](#)

Approval queue

State

Pending



Requests

State	Requester	Needed from	Needed until	Actions
Pending	6aab2a45c6e457e01ac0968d	Oct 1, 2026, 12:00 AM	Oct 15, 2026, 12:00 AM	Approve Deny

SafeDrop · CS673 Team 3 · Iteration 1

No user may approve their own request.

Separation of duties is enforced in the approval policy, not in the interface — so it holds for a direct API call too. Approving moves the request to APPROVED and the unit to HELD, and writes the audit entry in the same transaction.

Demo: Chain of Custody

Orelmis

History

30 events, newest first. This record cannot be edited.

1. **Asset checked out** unit xps-001
Ada Admin Organization admin
Sep 18, 2026, 12:00 AM
2. **Asset returned** unit xps-002
Ann Approver Approver
Sep 17, 2026, 12:00 AM
3. **Asset checked out** unit xps-001
Max Member Member
Sep 16, 2026, 12:00 AM
4. **Asset returned** unit xps-002
Ada Admin Organization admin
Sep 15, 2026, 12:00 AM
5. **Asset checked out** unit xps-001
Ann Approver Approver
Sep 14, 2026, 12:00 AM

SCRUM-29

One asset, its whole history

Unioned across the asset, its units, and every request against those units — with the actor and the role they held at the time.

It sits behind audit:read rather than assets:read, because what it returns is the audit trail reached by a different question.

Three target types, one query.

The history unions the events recorded against the Asset, against each of its AssetUnits, and against every CheckoutRequest raised on those units — paginated once, not three times. The record states on its face that it cannot be edited.

This is the view that answers the question from our Iteration 0 pitch: who has unit #247 right now, who approved it, and was it returned?

Demo: The Audit Log

Orelmis

SafeDrop [Catalog](#) [My requests](#) [Approvals](#) [Dashboard](#) [Users](#) [Audit log](#)

Ada Admin · Acme Robotics · Organization admin

[Sign out](#)

Audit log

Every request, approval, checkout, return and inventory change is recorded here and can never be edited or deleted.

Member	Action	Target	From	To
All members ▾	All actions ▾	All targets ▾	mm/dd/yyyy 📅	mm/dd/yyyy 📅

30 events

Audit events, newest first. This record cannot be edited.

When	Action	Actor	Target
Sep 18, 2026, 12:00 AM	Asset checked out	Ada Admin Organization admin	AssetUnit 6aab2a45c6e457e01ac990800
Sep 17, 2026, 12:00 AM	Request approved	Ada Admin Organization admin	CheckoutRequest 6aab2a45c6e457e01ac990801
Sep 16, 2026, 12:00 AM	Asset returned	Ada Admin Organization admin	AssetUnit 6aab2a45c6e457e01ac990802
Sep 15, 2026, 12:00 AM	Asset checked out	Ada Admin Organization admin	AssetUnit 6aab2a45c6e457e01ac990803
Sep 14, 2026, 12:00 AM	Request approved	Ada Admin Organization admin	CheckoutRequest 6aab2a45c6e457e01ac990804
Sep 13, 2026, 12:00 AM	Asset returned	Ada Admin Organization admin	AssetUnit 6aab2a45c6e457e01ac990805
Sep 12, 2026, 12:00 AM	Asset checked out	Ada Admin Organization admin	AssetUnit 6aab2a45c6e457e01ac990806
Sep 11, 2026, 12:00 AM	Request approved	Ada Admin Organization admin	CheckoutRequest 6aab2a45c6e457e01ac990807
Sep 10, 2026, 12:00 AM	Asset returned	Ada Admin Organization admin	AssetUnit 6aab2a45c6e457e01ac990808
Sep 9, 2026, 12:00 AM	Asset checked out	Ada Admin Organization admin	AssetUnit 6aab2a45c6e457e01ac990809
Sep 8, 2026, 12:00 AM	Request approved	Ann Approver Approver	CheckoutRequest 6aab2a45c6e457e01ac990810

Org Admin only, scoped and paginated

- Filters by member, action, target type and date range.
- The Member control is the actor filter added this iteration (SCRUM-46). The backend had always supported filtering by actor, but no control existed — so the acceptance criterion was unreachable through the interface.
- Entries record actor, the role held at the time, before and after state, a server-generated timestamp, and a request ID (SR-10).

Thirteen audit actions across five target types. Password hashes, tokens and other secrets are never written into before/after snapshots.

Quality Assurance and Testing

Orelmis

94.6%

backend line coverage
gate fails below 80%

96.0%

frontend line coverage
gate fails below 80%

921

test cases passing
across both packages

0

npm audit findings at
high or above

Three files that make the security design checkable

134

routePermissions — every route checked against the permission matrix, and 401 without a session

27

tenantIsolation — a token from one organization gets 404 — not 403 — for another's ids

72

checkout.transitions — every legal and illegal move of the state machine

How it runs

- Lint, format, the suite with coverage, npm audit and a Docker build — on every push and pull request.
- Integration tests run against a real MongoDB replica set in memory, so transactions and unique constraints behave as in production.
- Acceptance criteria for unbuilt work are staged as todo cases, so a story's definition of done lives in the suite.

All figures from the CI run on main at commit e4a0efd, 21 September 2026, which passed all six jobs. Playwright end-to-end tests were not written this iteration.

Configuration and Deployment

Alex

1

Push / PR

feature branch,
protected main

2

Six CI jobs

lint · format · tests
CodeQL · audit · Docker

3

Peer review

second member approves;
PR template carries the DoD

4

Merge to main

mirrors to the deploy repo
Vercel + Render rebuild

5

ZAP on staging

dynamic scan before
a release is promoted

Local, CI and staging run the same images

- Everyone runs the stack through the committed Docker Compose file; CI builds the same images Render deploys.
- Every environment variable is documented in `.env.example` with a dev-only default.

Where we are honest about it

- Production promotion is still a placeholder job. Staging is what is live.
- The staging mirror and both hosting accounts depend on one team member — logged this iteration as a key-person risk.

Staging: [safe-drop-five.vercel.app](#) and [safedrop-ony6.onrender.com](#). Local and CI run an ephemeral MongoDB; staging runs Atlas free tier.

Security by Design

Amber

Access control

SR-1, SR-2

Tenant ID comes only from the verified token, never the URL or body. Every repository function takes it as its first parameter. Another tenant's id returns 404, not 403, so existence never leaks.

Identity & transport

SR-3 – SR-7

bcrypt at cost 12. Short-lived access token, rotating refresh token, httpOnly and Secure cookies, 30-minute idle timeout. Reuse of a rotated token revokes the whole session.

Audit integrity

SR-8 – SR-10

Append-only repository with no update or delete path. The audit entry commits in the same transaction as the state change, so neither can exist without the other.

Operational

SR-11 – SR-14

Secrets in environment variables only. CodeQL and npm audit on every pull request, ZAP against staging, rate limits on authentication, CORS allowlisted per environment.

Fourteen security requirements, each traced in SDD §6.10 to the design element that satisfies it and the test that verifies it.

Two Findings, Reported Honestly

Amber

CLOSED

Unbounded anonymous tenant creation

SCRUM-114

- The organization bootstrap route is public by necessity — it creates a new organization and its first admin — but it was uncapped.
- Reproduced: 12 anonymous requests created 12 organizations and 12 admin accounts, each costing roughly 330 ms of bcrypt work.
- Fixed at 5 per IP per hour, counting successes rather than failures, because here the successes are the abuse. Merged in PR #43 with three integration tests.

OPEN

Audit immutability at the database layer

SCRUM-125 · SR-8 partially satisfied

- Our design promises immutability at two layers. The application layer is done and tested. The database layer is not.
- The API's database user still holds a role that could update or delete audit rows, so anything bypassing Mongoose is not stopped.
- The insert-only role and its test are written and merged in PR #44. Applying it is blocked on Atlas console access. Until then SR-8 rests on the application layer alone.

Both are in the risk register with owners and dates. We would rather present SR-8 as partially satisfied than claim a layer that is not switched on.

How the Iteration Ran

Alexa

30 / 40

sprint items done
as of 21 September

4

in review,
3 in progress

5

new risks logged
this iteration

2

security findings
raised and tracked

A metric of ours that broke

- Only 9 of 40 sprint items carry story points, and 23 of the 30 completed items have none — including most of the implementation work.
- So velocity in points would understate this iteration badly, and we are reporting item counts instead.
- The whole backlog gets pointed before Iteration 2 planning, so the next report has a number worth trusting.

Cadence and risk

- Weekly team meeting plus a second review meeting before every deliverable. Leadership roles rotate each iteration.
- Five risks added from what we actually hit: dev/prod parity, key-person dependency, external hostname dependency, and the two security findings.
- The register is re-scored at every iteration boundary, not written once and filed.

Sprint "Iteration 1" runs 18–26 September; these figures are as of 21 September. Twenty-eight risks are now tracked across eight categories.

NEXT: ITERATION 2

What we take into the next two weeks

Configurable approvals

Policies per item, per equipment group and per user tier

Finish SR-8

Apply the insert-only audit role and turn the staged test on

Two-step return

Condition capture at return, carried over from SCRUM-57

Point the backlog

So Iteration 2 reports a velocity worth trusting

Repository

github.com/BUMETCS673/CS673OLF26P3

Staging

safe-drop-five.vercel.app

Thank you — questions welcome in the discussion thread.